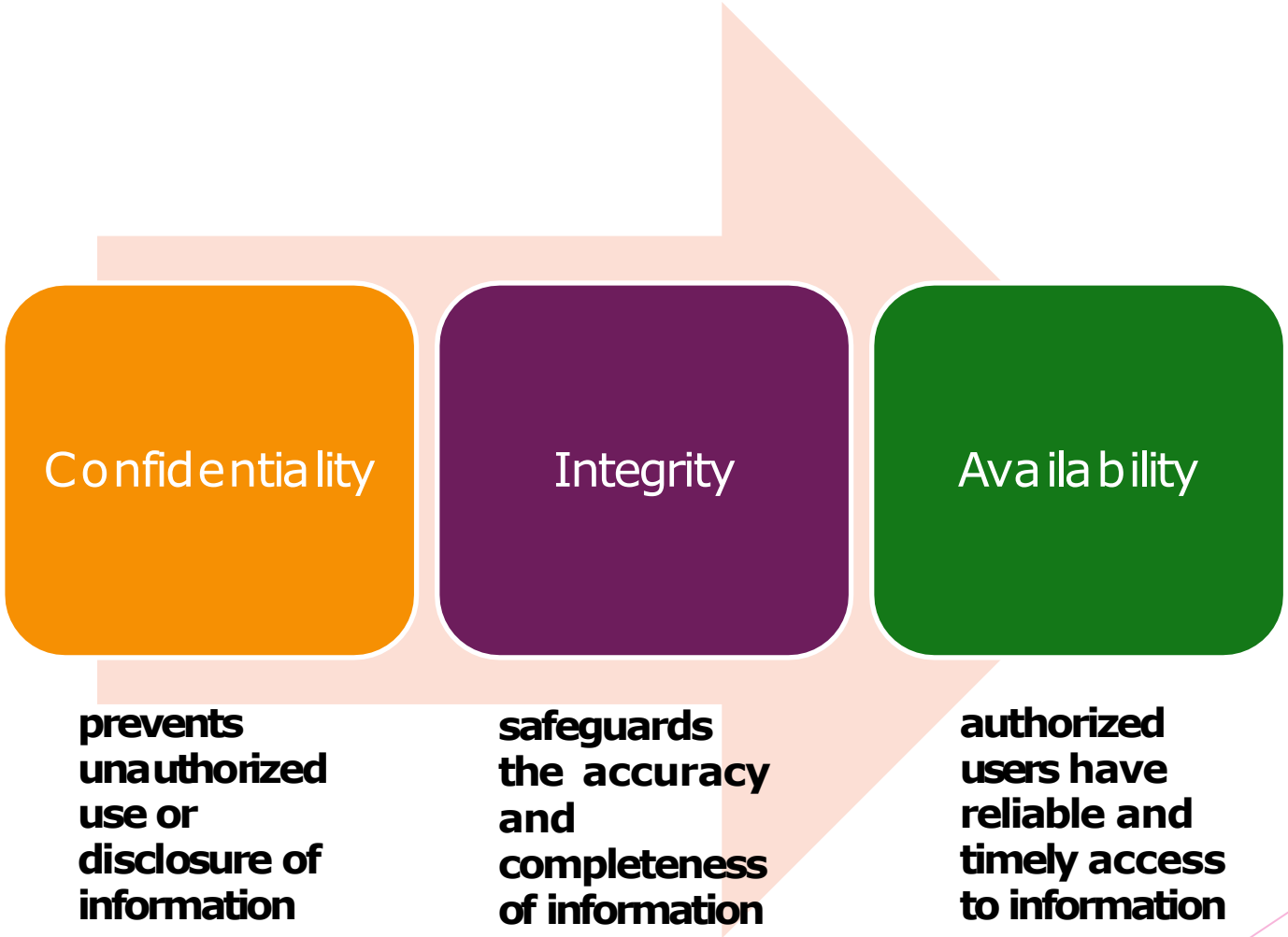
System And Network Security

Goals of Information Security



SECURITY

Why Security?

- The Internet was initially designed for connectivity
  - Trust assumed
  - We do more with the Internet nowadays
  - Security protocols are added on top of the TCP/IP
- Fundamental aspects of information must be protected
  - Confidential data
  - Employee information
  - Business models
  - Protect identity and resources
- We can’t keep ourselves isolated from the Internet
  - Most business communications are done online
  - We provide online services
  - We get services from third-party organizations online

Basics of Network security

- **Plain Text-**

Plaintext is **usually ordinary readable text before it is encrypted into ciphertext, or readable text after it is decrypted**. For example, plaintext emails are **messages that contain only text**

- **Cipher Text –**

Ciphertext is **encrypted text transformed from plaintext using an encryption algorithm**. Ciphertext can't be read until it has been converted into plaintext (decrypted) with a key. The decryption cipher is an algorithm that transforms the ciphertext back into plaintext

- **Encryption -**

Encryption is **a security method in which information is encoded in such a way that only authorized user can read it**.

- **Decryption** –

Decryption is a technique that is used in cyber security that **makes it challenging for hackers to intercept and read unauthorized information**. A reverse process of encryption is known as Decryption. It is **a procedure of transforming Cipher Text into Plain Text**.

- **Cryptography –**

Cryptography is **a method of protecting information and communications through the use of codes**, so that only those for whom the information is intended can read and process it.

- **Cryptanalyst –**

Cryptanalysis is **the study of methods for obtaining the meaning of encrypted information, without access to the secret information that is typically required to do so**.

- **Key –**

A **network security key** is the password that protects your network.

Categories of Security Service

- Authentication- Authentication is **used by a server when the server needs to know exactly who is accessing their information or site**. Authentication is used by a client when the client needs to know that the server is system it claims to be. In authentication, the user or computer has to prove its identity to the server or client.
- Authorization- Authorization is **a process by which a server determines if the client has permission to use a resource or access a file**. Authorization is usually coupled with authentication so that the server has some concept of who the client is that is requesting access.
- Non – Repudiation- Assurance that the sender of information is provided with proof of delivery and the recipient is provided with proof of the sender's identity, so neither can later deny having processed the information.
- Auditing- **Network security audit** gives organizations a complete analysis of their security systems.

Security Attacks

- Passive – 1. Release of Message Content
  2. Traffic Analysis
- Active

Security Attacks

- **Active attack**

1. Modifies the data
2. Affects the system
3. Can be easily detected
4. Threat to integrity and availability
5. Capture physical control over the link

- **Passive Attack**

1. Monitor data
2. Does not affect the system
3. Cannot be easily detected
4. Threat to confidentiality
5. Just observe the transmission
6. Prevention

Security Mechanism

- Encipherment- This is **the procedure of using numerical algorithms to change data into a form that is not freely intelligible**.
- Digital signature- **Digital signature** is like a fingerprint or an attachment to a **digital** document that ensures its authenticity and integrity.
- Access control- Access control is **a fundamental component of data security that dictates who's allowed to access and use company information and resources**.
- Authentication Exchange- Authentication is **the act of confirming the identity of a user**. Authentication is a key function of Exchange Network Nodes, since most Node services require authentication before they can be used. Authenication to a Node is achieved by calling an “Authenticate” web method on the Node.
- Traffic podding- **he generation of spurious instances of communication, spurious data units, and/or spurious data within data units**. Note: May be used to disguise the amount of real data units being sent.
- Routing Control- outing control **allows selection of specific physically secure routes for specific data transmission and enables routing changes, particularly when a gap of security is suspected**. Notarization − This is the usage of a trusted third party to assure specific properties of an information exchange

What is authentication?

- Positive verification of identity (man or machine)
- Verification of a person's claimed identity
- Who are you? Prove it.
- 3 Categories:
  - What you know
  - What you have
  - Who you are

What you know

- Password
- Passphrase
- PIN

What you have

- Digital authentication
  - physical devices to aid authentication
- Common examples:
  - eToken
  - smart cards
  - RFID

eToken

- Can be implemented on a USB key fob or a smart card
- Data physically protected on the device itself
- On the client side, the token is accessed via password
- Successful client-side authentication with the password invokes the token to generate a stored or generated **passcode**, which is sent to the server-side for authentication.

eToken

- May store credentials such as passwords, digital signatures and certificates, and private keys
- Can offer on-board authentication and digital signing

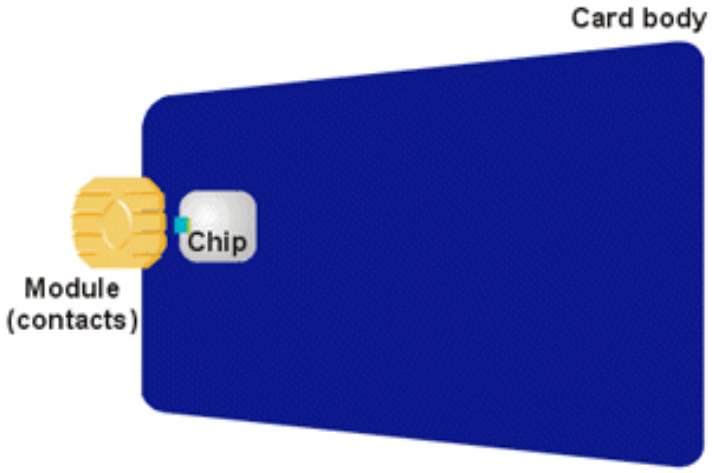


Smart cards

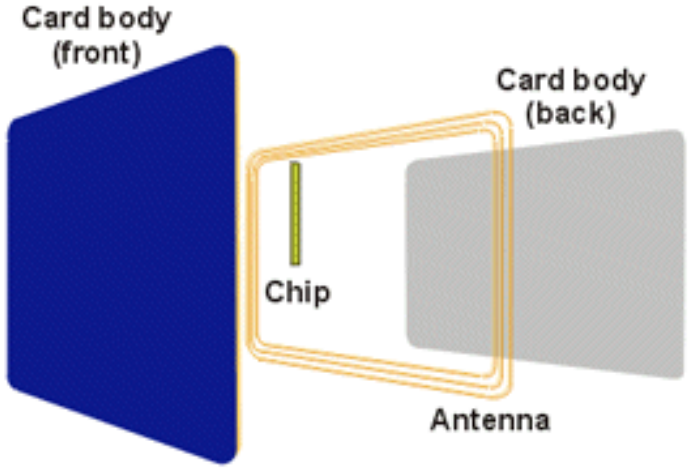
- Size of a credit card
- Usually an embedded microprocessor with computational and storage capabilities
- Programmable platforms:
  - C/C++
  - Visual Basic
  - Java
  - .Net (beta)

Smart Cards cont'd

- Contact vs. contactless
- Memory vs. microprocessor



Source: Gemplus - All About Smart Cards



Source: Gemplus - All About Smart Cards

RFID

- RFID - Radio Frequency IDentification
- Integrated circuit(s) with an antenna that can respond to an RF signal with identity information
- No power supply necessary—IC uses the RF signal to power itself
- Susceptible to replay attacks and theft
- Examples:
  - Smart Tag, EZPass
  - Garage parking permits

RFID

- 13.56Mhz read/write support
- May communicate with a variety of transponders (ISO15693, ISO14443 Type A & B, TagIt, Icode, etc.)
- Reader is controlled via PCMCIA interface using an ASCII protocol



Who you are

- Biometric authentication
  - Use of a biometric reading to confirm that a person is who he/she claims to be
- Biometric reading
  - A recording of some physical or behavioral attribute of a person

Physical Biometrics

- Fingerprint
- Iris
- Hand Geometry
- Finger Geometry
- Face Geometry
- Ear Shape
- Retina

- Smell
- Thermal Face
- Hand Vein
- Nail Bed
- DNA
- Palm Print

Behavioral Biometrics

- Signature
- Voice
- Keystroke
- Gait

Fingerprints

- Vast amount of data available on fingerprint pattern matching
- Data originally from forensics
- Over 100 years of data to draw on
  - Thus far all prints obtained have been unique

Fingerprint Basics

- Global features
  - Features that can be seen with the naked eye
  - Basic ridge patterns
- Local features
  - Minutia points
  - Tiny unique characteristics of fingerprint ridges used for positive identification

Basic Ridge Patterns

- Loop
- 65% of all fingerprints



- Arch
- Plain and tented arch



- Whorl
- 30% of all fingerprints
- One complete circle



Local Features

- Also known as *minutia points*
- Used for positive identification
- Two or more individuals may have the same global features, but different minutia
- Minutia points do not have to be inside the pattern area

Password Strengths

The strength of a password is determined by three things: the length of the character set used, the length of the password itself, and to a lesser extent, the variety in characters chosen.

- For security-critical systems, we recommend using 16-character randomly generated passwords. Passwords should include lowercase and uppercase characters, numbers, and special characters with equal probability.
- **The stronger your password, the more protected your computer will be from hackers and malicious software**. You should maintain strong passwords for all accounts on your computer.

Entropy

- A measure of the amount of uncertainty an attacker faces to determine the value of a secret.
- Entropy, in cyber security, is **a measure of the randomness or diversity of a data-generating function**. Data with full entropy is completely random and no meaningful patterns can be found. Low entropy data provides the ability or possibility to predict forthcoming generated values.
- In cryptography, **entropy is used to produce random numbers, which in turn are used to produce security keys to protect data while it's in storage or in transit**. The greater the quality of random number generation (RNG), the greater the quality of random keys produced, and thus the higher the security value of the key.
- **Melting ice** makes a perfect example of entropy. As ice the individual molecules are fixed and ordered. As ice melts the molecules become free to move therefore becoming disordered. As the water is then heated to become gas, the molecules are then free to move independently through space

INTRODUCTION

- USERS FIRST MUST BE IDENTIFIED AS AUTHORIZED USER, SUCH AS BY LOGGING IN WITH USER NAME AND PASSWORD TO LAPTOP COMPUTER
- BECAUSE LAPTOP CONNECTS TO CORPORATE NETWORK THAT CONTAINS CRITICAL DATA, IMPORTANT ALSO TO RESTRICT USER ACCESS TO ONLY SOFTWARE, HARDWARE, AND OTHER RESOURCES FOR WHICH USER HAS BEEN APPROVED
- THESE TWO ACTS—AUTHENTICATING ONLY APPROVED USERS AND CONTROLLING THEIR ACCESS TO RESOURCES—ARE IMPORTANT FOUNDATIONS IN INFORMATION SECURITY

WHAT IS ACCESS CONTROL?

- ACCESS CONTROL – GRANTING OR DENYING APPROVAL TO USE SPECIFIC RESOURCES; IT IS CONTROLLING ACCESS
- *PHYSICAL ACCESS CONTROL* – FENCING, HARDWARE DOOR LOCKS, AND MANTRAPS THAT LIMIT CONTACT WITH *DEVICES*
- *TECHNICAL ACCESS CONTROL* – TECHNOLOGY RESTRICTIONS THAT LIMIT USERS ON COMPUTERS FROM ACCESSING *DATA*

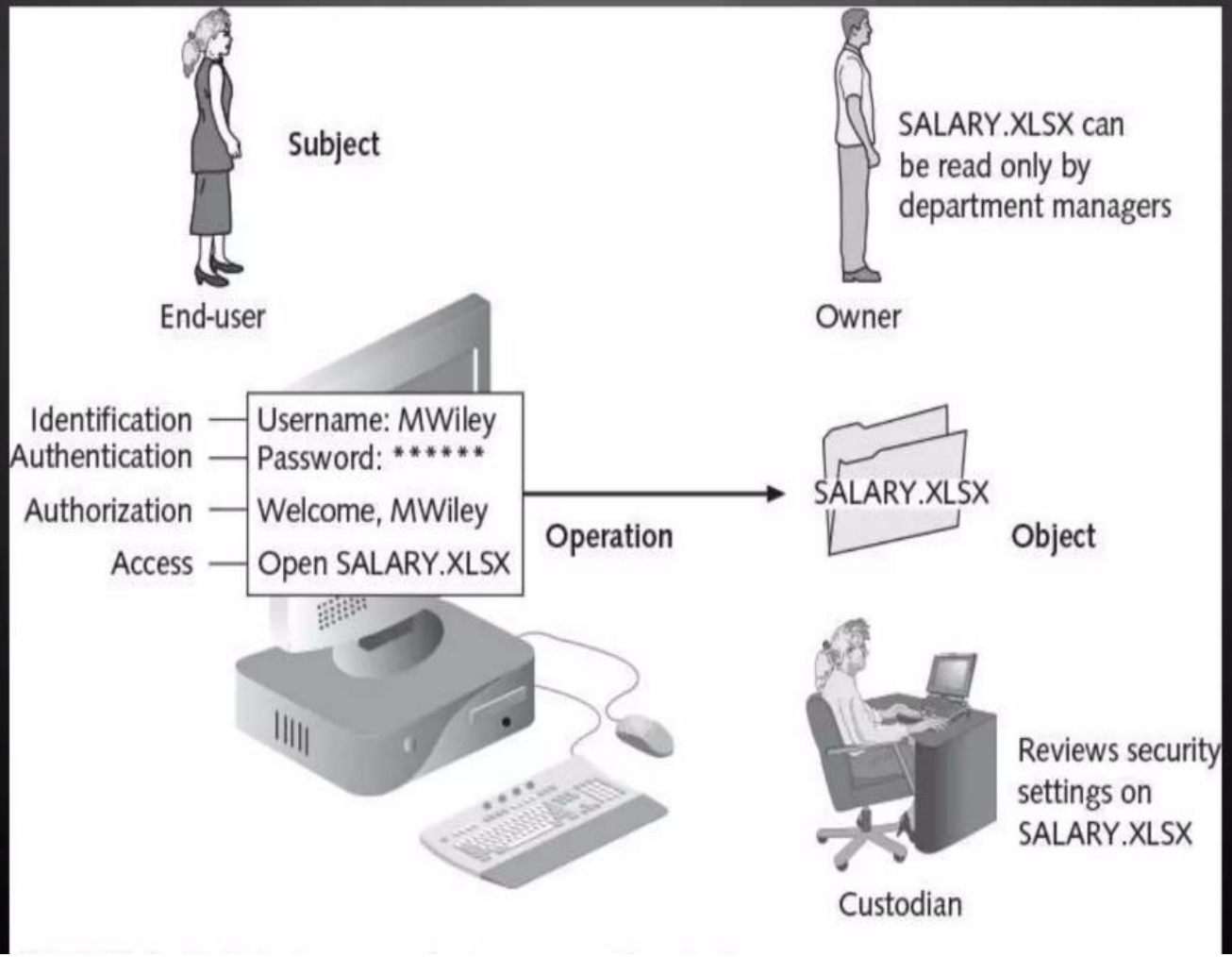
ACCESS CONTROL TERMINOLOGY

- *IDENTIFICATION* – PRESENTING CREDENTIALS (EXAMPLE: DELIVERY DRIVER PRESENTING EMPLOYEE BADGE)
- *AUTHENTICATION* – CHECKING CREDENTIALS (EXAMPLE: EXAMINING THE DELIVERY DRIVER'S BADGE)
- *AUTHORIZATION* – GRANTING PERMISSION TO TAKE ACTION (EXAMPLE: ALLOWING DELIVERY DRIVER TO PICK UP PACKAGE)

Action	Description	Scenario example	Computer process
Identification	Review of credentials	Delivery person shows employee badge	User enters user name
Authentication	Validate credentials as genuine	Gabe reads badge to determine it is real	User provides password
Authorization	Permission granted for admittance	Gabe opens door to allow delivery person in	User authorized to log in
Access	Right given to access specific resources	Delivery person can only retrieve box by door	User allowed to access only specific data

Table 11-1 Basic steps in access control

TECHNICAL ACCESS CONTROL PROCESS



ACCESS CONTROL MODELS

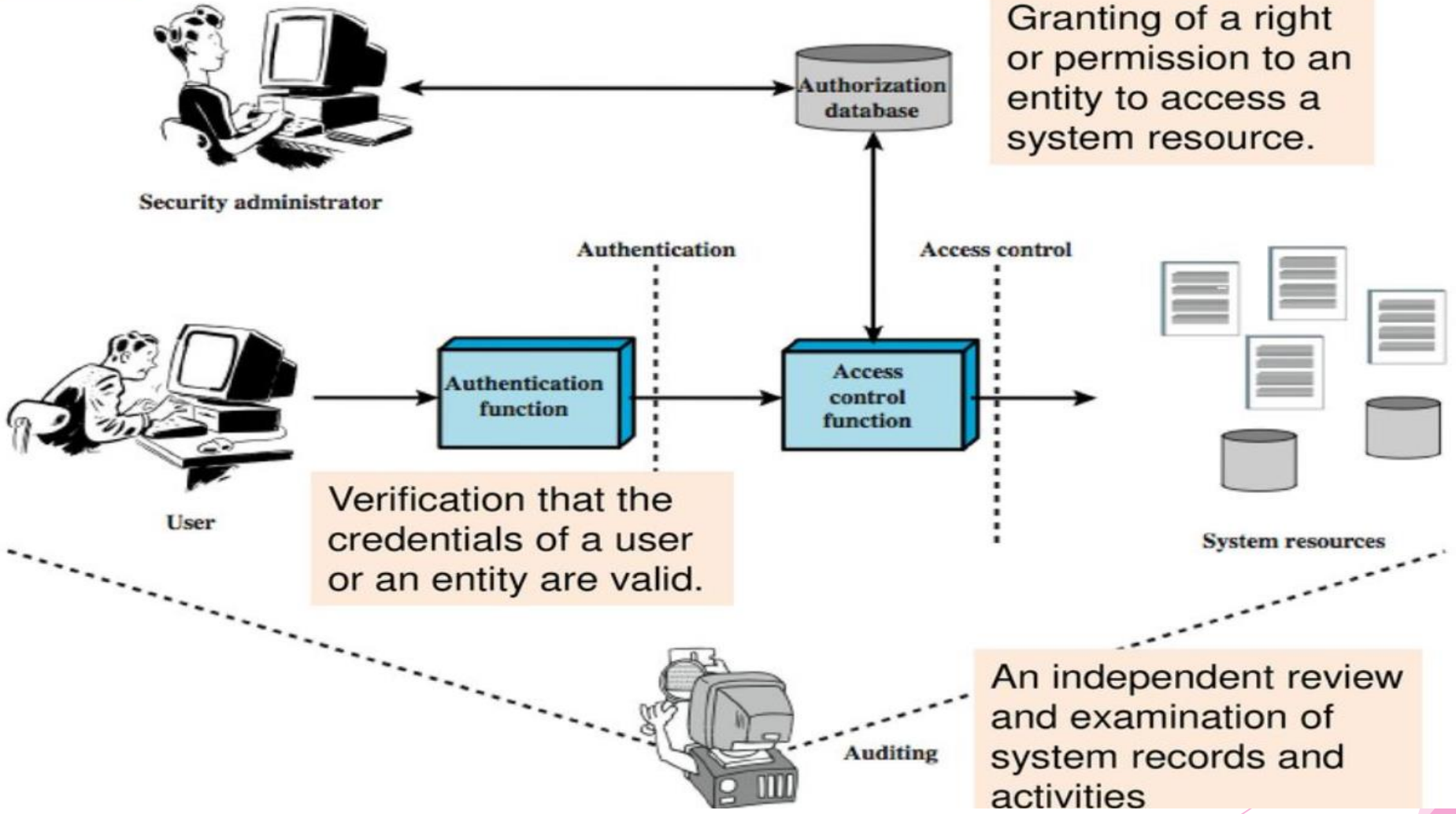
- ACCESS CONTROL MODEL – HARDWARE AND SOFTWARE PREDEFINED *FRAMEWORK* THAT CUSTODIAN CAN USE FOR CONTROLLING ACCESS
- ACCESS CONTROL MODELS USED BY CUSTODIANS FOR ACCESS CONTROL ARE NEITHER CREATED NOR INSTALLED BY CUSTODIANS OR USERS; INSTEAD, THESE MODELS ARE ALREADY PART OF SOFTWARE AND HARDWARE.
- ACCESS CONTROL MODELS
  - DAC – LEAST RESTRICTIVE MODEL
  - MAC – OPPOSITE OF DAC AND IS MOST RESTRICTIVE ACCESS CONTROL MODEL
  - UAC – USER/ADMIN LEVEL MODEL THAT NOTIFIES OR REQUIRES AUTHENTICATION PRIOR TO GRANTING ACCESS

ACCESS CONTROL MODELS

Name	Restrictions	Description
Mandatory Access Control (MAC)	End-user cannot set controls	Most restrictive model
Discretionary Access Control (DAC)	Subject has total control over objects	Least restrictive model
Role Based Access Control (RBAC)	Assigns permissions to particular roles in the organization and then users are assigned to roles	Considered a more "real-world" approach
Rule Based Access Control (RBAC)	Dynamically assigns roles to subjects based on a set of rules defined by a custodian	Used for managing user access to one or more systems

Table 11-3 Access control models

Access Control Principles

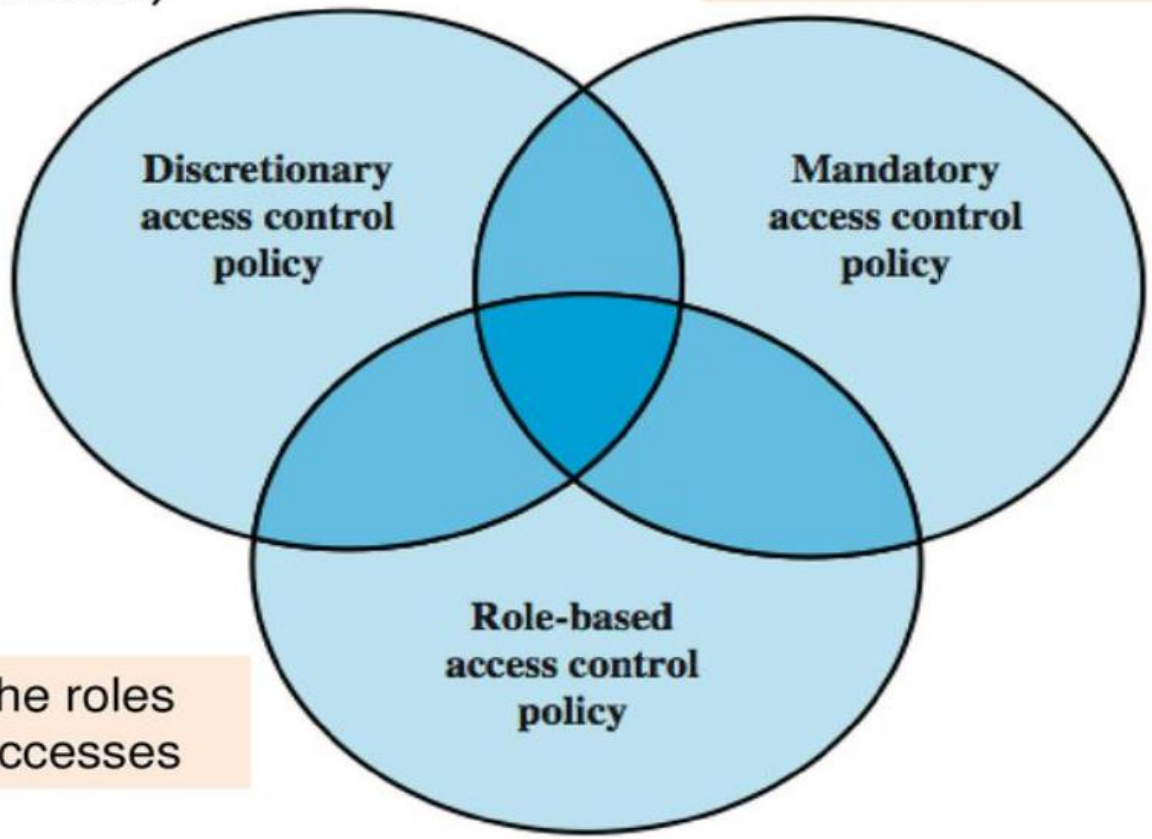


Access Control Policies

- dictates
  - what types of access are permitted,
  - under what circumstances,
  - by whom.

based on comparing security labels with clearances

based on the identity of the requestor and on access rules



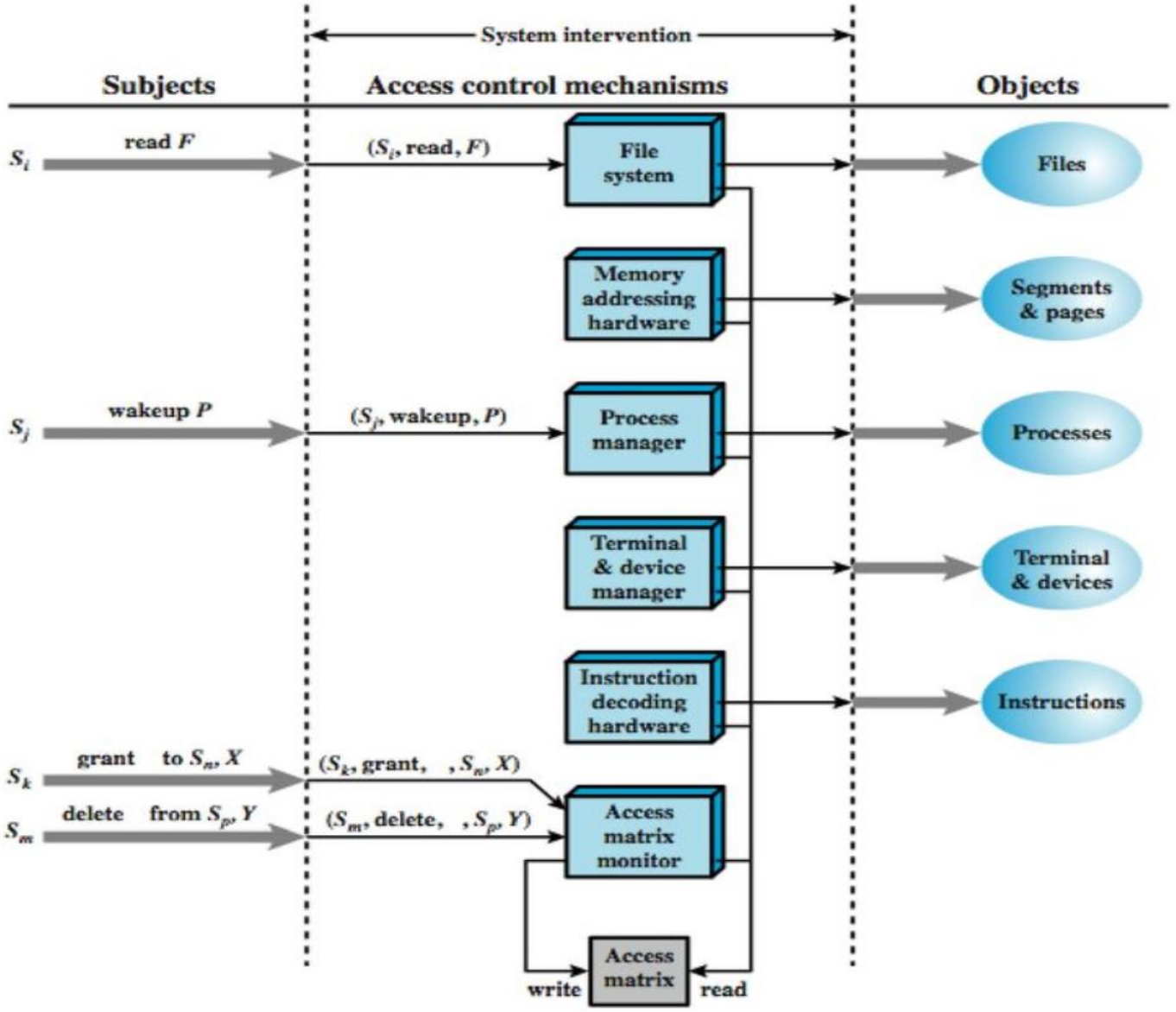
based on the roles and their accesses



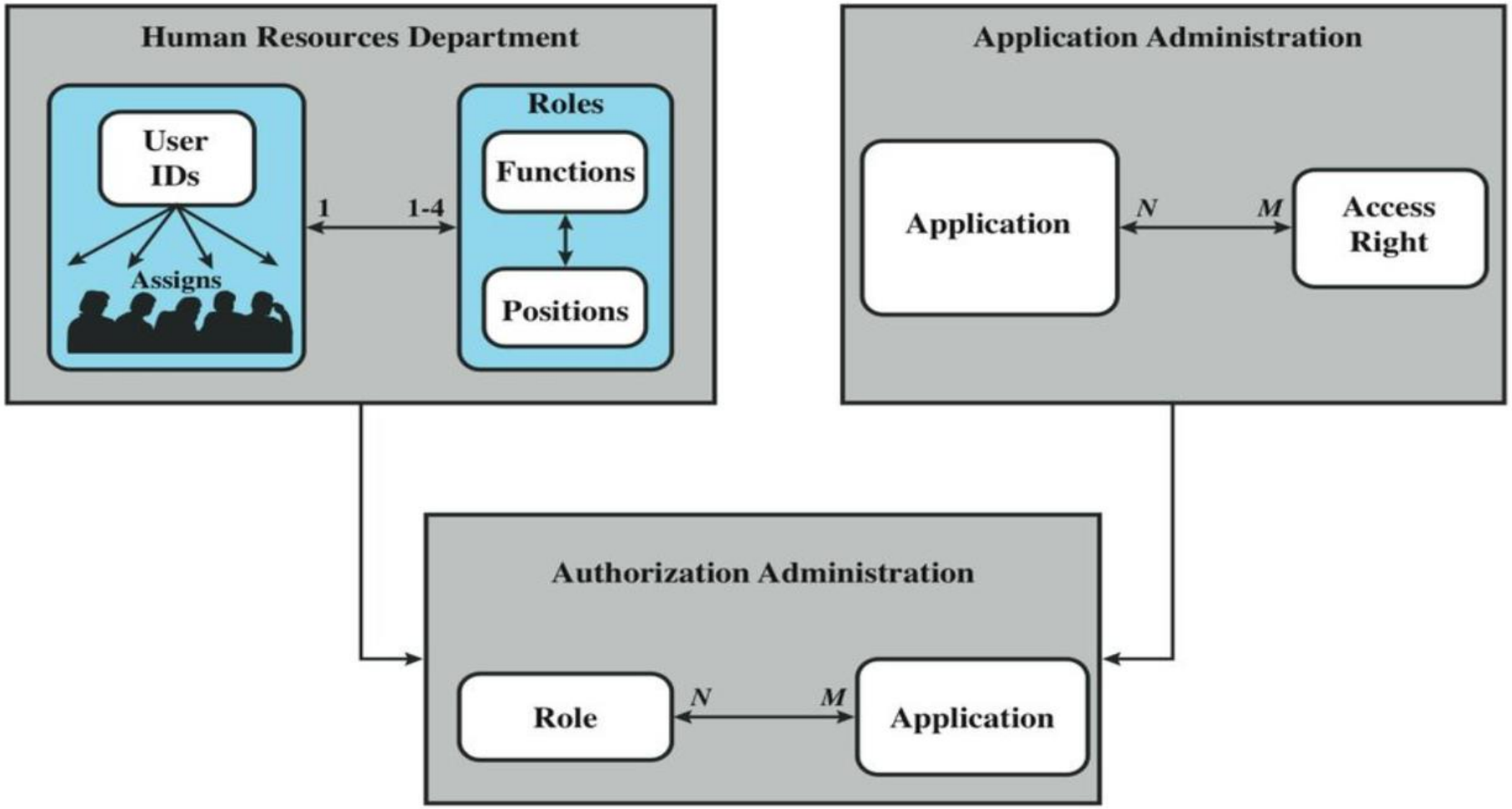
Access Control Requirements

- reliable input
- support for fine and coarse specifications
- least privilege
- separation of duty
- open and closed policies
- policy combinations and conflict resolution
- administrative policies
- dual control

Access Control Function



Example of Access Control Administration

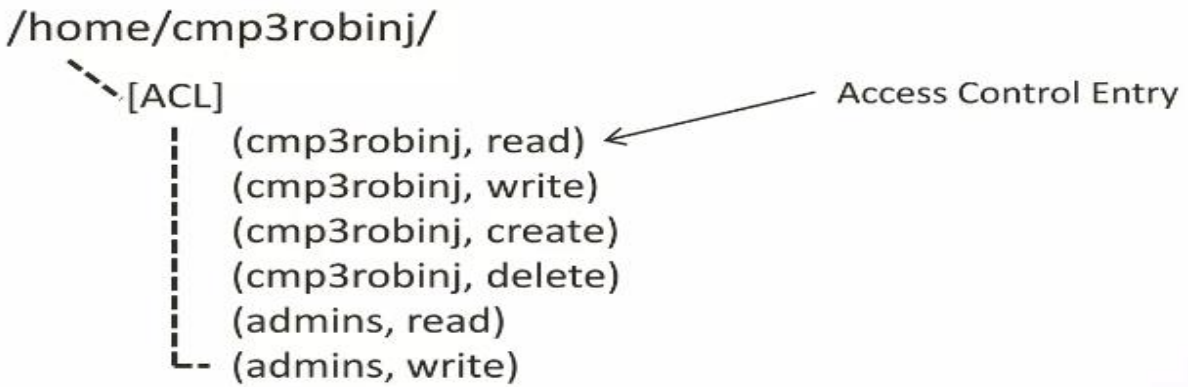


Permissions

- A privilege granted to a user, group or computer to perform a particular action or access a particular resource.
- Windows Server 2008 has many different sorts of permissions – most visible are:
  - File-system – access to files & folders under NTFS.
  - Share – access to file system and printer shares.
  - AD – access to Active Directory objects.
  - Registry – access to registry keys.
- They are all separate/different!

Access Control Lists (ACL)

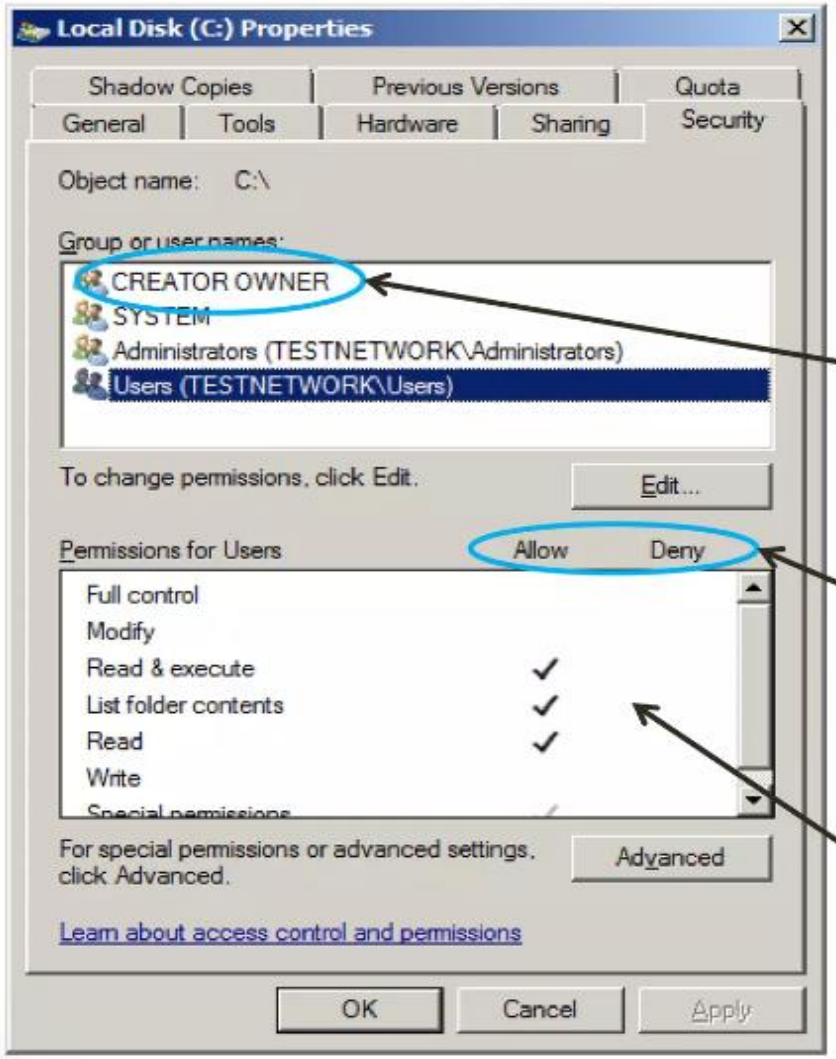
- An Access Control List is associated to an object being accessed, not the object accessing it.
- Lists all permissions that can *access* that object. (e.g. users, groups, etc.)
- Also lists what *operations* can be done to the object.
- List made out of Access Control Entries (ACE's) (i.e. the name of the security principle and the permissions it has been granted)
- Example:



NTFS Permissions

- Mostly can use Standard permissions for NTFS files and folders:
  - Read, Read & Execute, Write, Modify, List Folder Contents, Full Control
- Occasionally need to set up more fine-grained, using the 14 NTFS Special Permissions.
  - The Standard permissions are just a convenient grouping into most frequently used sets.
- There are slight differences when permissions are applied to a file rather than a folder (and List Folder Contents is obviously not applicable to files!)

Example Permissions

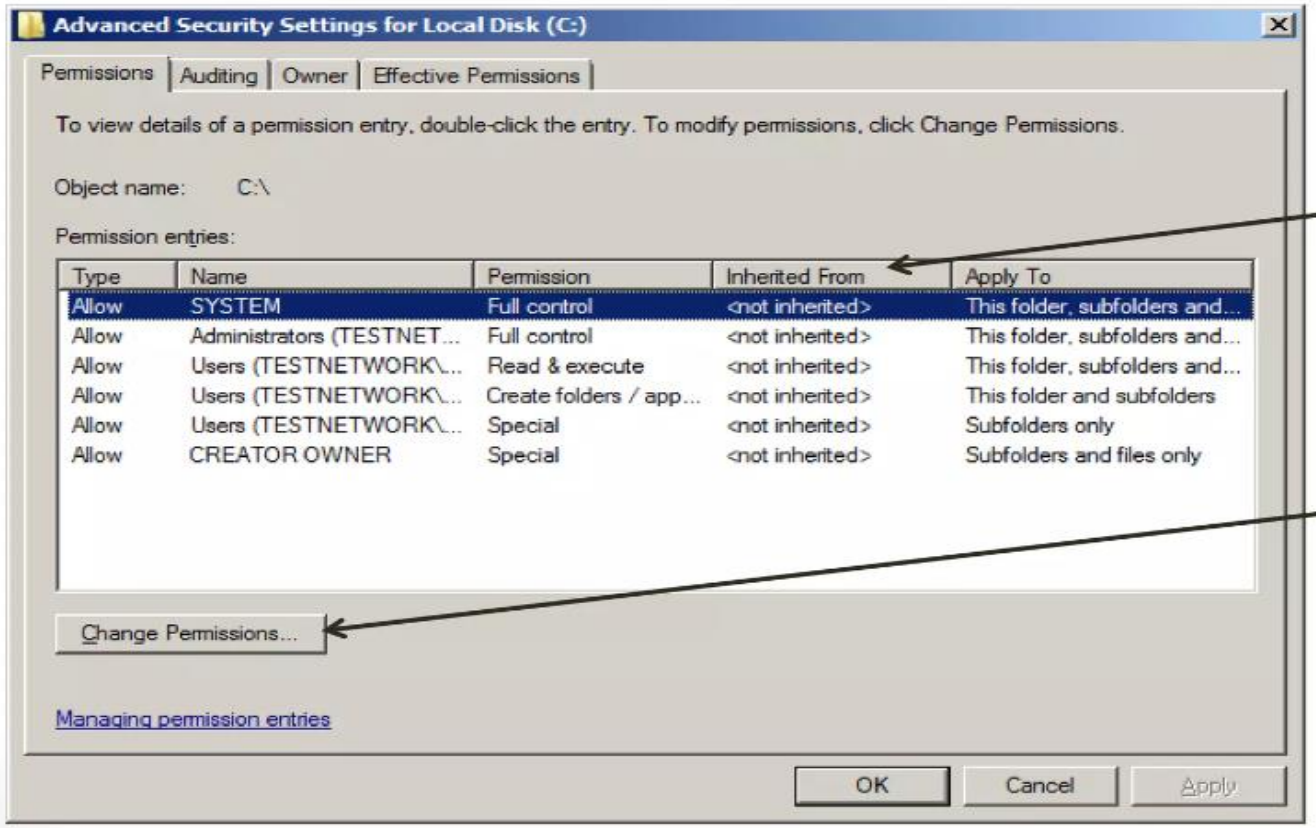


Creator Owner is a 'Special User'. Will discuss again later.

Permissions can be explicitly *Allowed* or *Denied.*

Note: list in this case gives Users Read & Execute, List folder contents and read permissions only.

Access to Special Permissions



Note that permissions can be inherited from higher folders (not applicable when it's c:)

To make more detailed changes, need to edit an individual ACE.

Example Permissions Breakdown

"Read & Execute" is composed of:

- List Folder/Read Data
- Read Attributes
- Read Extended Attributes
- Read Permissions
- Synchronise
- Traverse Folder/Execute File

Lets security principals move through inaccessible folders to reach folders / files they are allowed to access.

Without this, get *"Read"* Standard Permissions.

WHAT IS A PROTOCOL AND HTTP?

- Protocol: A Protocol is a standard procedure for defining and regulating communication. For example TCP, UDP, HTTP etc.
- HTTP is the foundation of data communication for the World Wide Web.
- The HTTP is the Web's application-layer protocol for transferring various forms of data between server and client like plaintext, hypertext, image, videos and sounds .

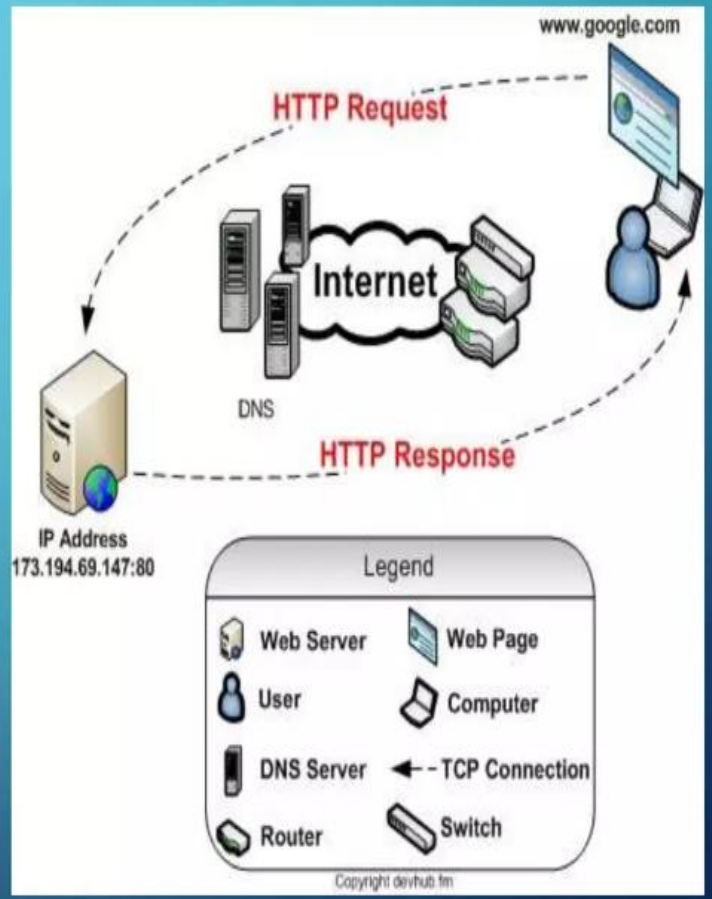


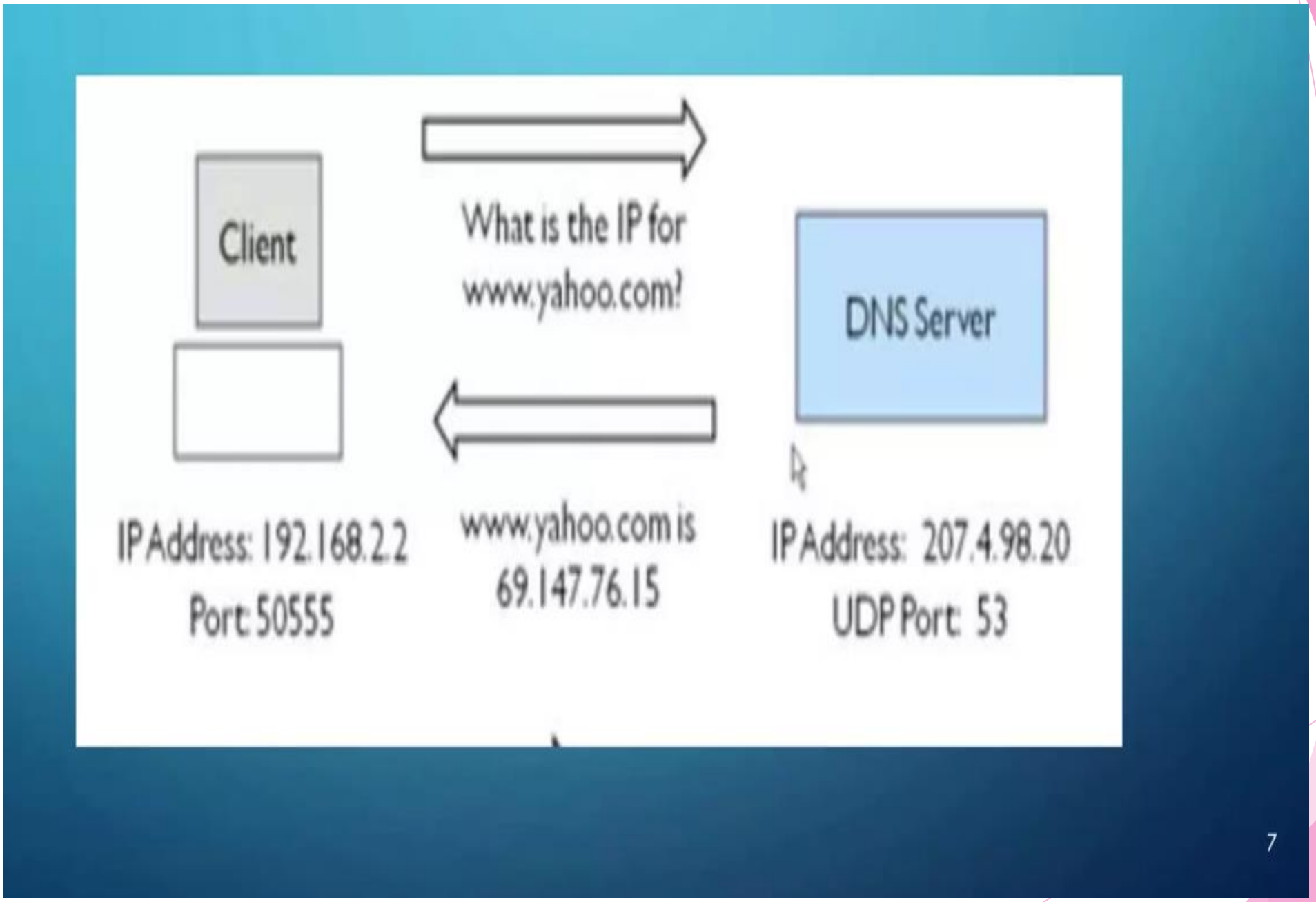
TERMINOLOGY

- IP Address: An Internet Protocol address (IP address) is a numerical label assigned to each device (e.g., computer, printer) participating in a computer network that uses the Internet Protocol for communication.
- TCP :Transmission Control Protocol (TCP) is one of the two original core protocols of the Internet Protocol Suite (IP), and is so common that the entire suite is often called *TCP/IP*. TCP provides reliable, ordered, error-checked delivery of a stream of octets between programs running on computers connected to an intranet or the public Internet.
- Port Number : A port number is a 16 bit number which when associated with IP address , completes the destination address for a communications session.
- Socket : A socket is nothing but a combination of IP address and port number. It is simply an end while communication.

HOW HTTP WORKS?

- HTTP is implemented in two programs: a client program and a server program, executing on different end systems, talk to each other by exchanging HTTP messages.
- The HTTP client first initiates a TCP connection with the server. Once the connection is established, the browser and the server processes access TCP through their socket interfaces.




Client
What is the IP for
www.yahoo.com?
DNS Server
IP Address: 192.168.2.2
Port: 50555
www.yahoo.com is
69.147.76.15
IP Address: 207.4.98.20
UDP Port: 53

PERSISTENT AND NON-PERSISTENT CONNECTIONS

- In non-persistent connection each request/response pair are sent over a separate TCP connection.
- In persistent connections all of the requests and their corresponding responses are sent over the same TCP connection.

HTTP: A STATELESS PROTOCOL

- HTTP is a stateless protocol, because an HTTP server maintains no information about the clients.
- If a particular client asks for the same object twice in a period of a few seconds, the server does not respond by saying that it just served the object to the client; instead, the server resends the object, as it has completely forgotten what it did earlier.

What is a digital signature

- A digital signature allows the holder of the secret key (the signing key) to sign a document
- Everyone who knows the verification key can verify that the signature is valid (correctness)
- No one can forge a signature even given the verification key even though he is given a signature

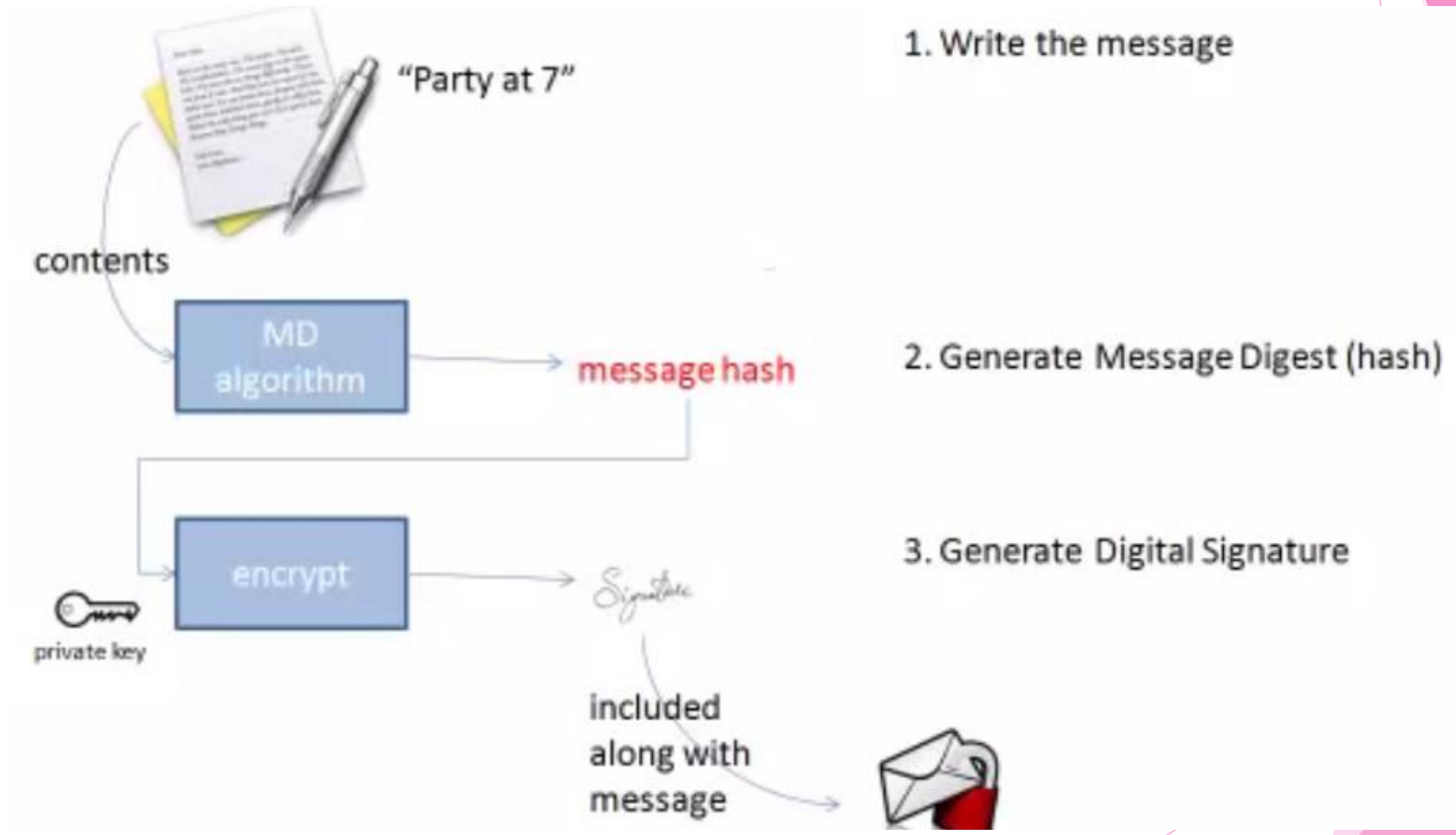
Digital Signature

1. Digital Signature is a type of electronic signature that encrypts documents with digital codes that are particularly difficult to duplicate

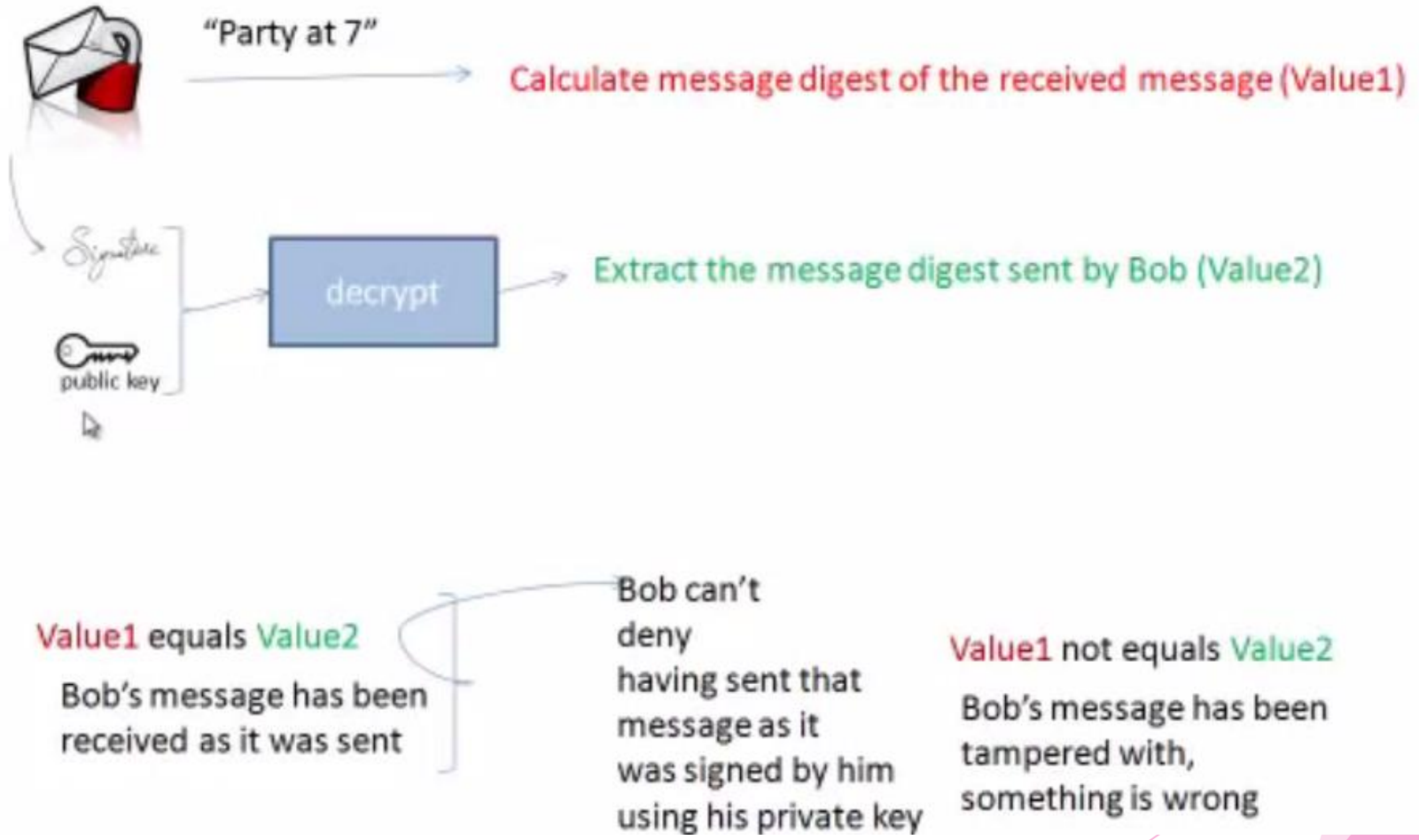
2. In case of digital signature message is encrypted with the private key and decrypted with the public key.


BOB
FRANK
Bob wants to send an important message to Frank
private key
public key
public key
DEVIL

On BOB

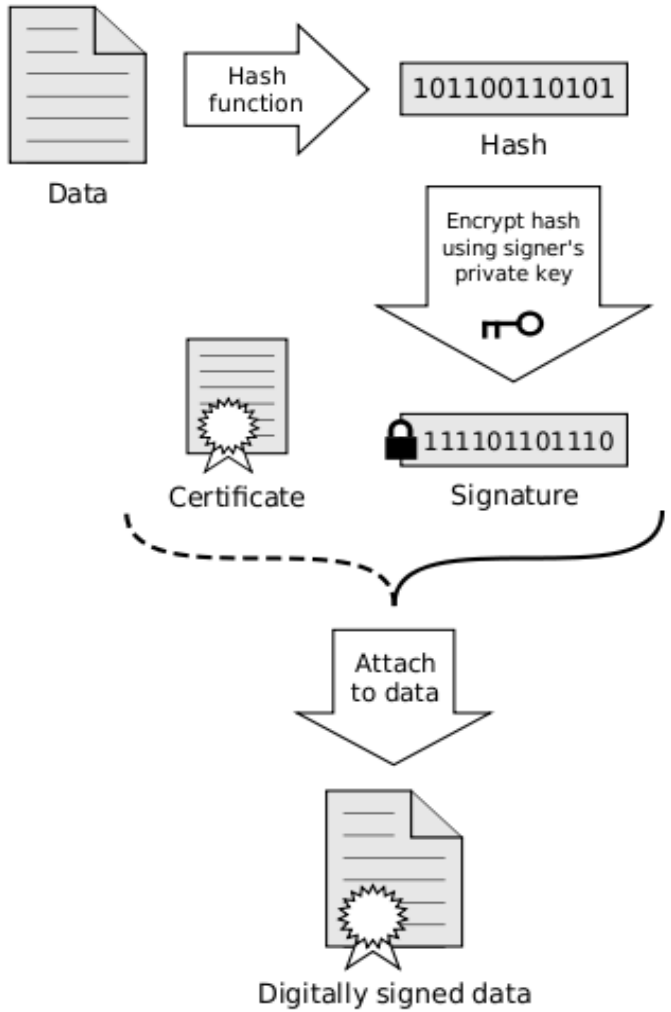

"Party at 7"
contents
MD algorithm
message hash
encrypt
private key
included along with message
1. Write the message
2. Generate Message Digest (hash)
3. Generate Digital Signature

On FRANK side

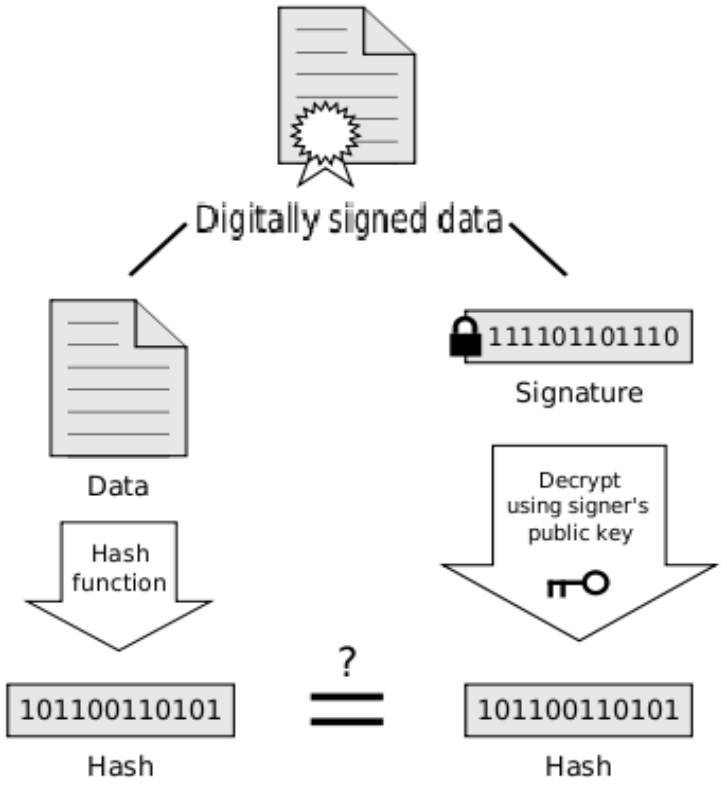


Digital Signature Algorithm

Signing



Verification



If the hashes are equal, the signature is valid.

At Sender Side

1. Message digest is generated using a set of Hash functions.

2. A message digest is encrypted using senders private key.

3. The resulting encrypted message is known as digital signature.

4. Digital signature is attached with data or message and send to receiver.

At Receiver Side

1. Receiver uses senders public key to decrypt senders digital signature to obtain message digest send by receiver.

2. Receiver uses same message digest algorithm, which is used by sender

3. Now, receiver will compare these two message digest

4. If message digest are equal then signature is valid else not.

Advantages

- Authentication:
  - Identification of person sign.
- Integrity od data:
  - Every change is detected.
- Non Repudiation:
  - Author has encrypted sign on message.
- Speed:
  - Contracts are easily written, completed, and signed by all concerned parties in a little amount of time no matter how far the parties are geographically.

Disadvantages

- Expiry
- Certificate issue procedures
- Software compatibility